



PhishGuard AI: Gmail 피싱 탐지 확장

AI 기반 이메일 보안 보조 도구 | Gmail 환경에서 피싱 위험도 분석 |
Chrome Manifest V3 기반 확장 프로그램

시큐어탭(김지훈, 김익경, 포엠사바르드 소반나봉, 응엔 껀 비엔)



목차

프로젝트 개요

Gmail 메일 분석 및 위험도 분류
AI 기반 HIGH/MEDIUM/LOW 판정
브라우저 내 독립 실행 구조

문제 정의

피싱 메일의 위협: 계정·결제 정보 탈취
발신자·링크 위장 기법
사용자 판단 지원 도구 필요성

해결 아이디어

Gmail 화면 내 실시간 감지
로컬 규칙 + AI 분석 결합
위험도와 판단 근거 제공

주요 기능 및 AI 분석 방식

메일 자동 감지 및 위험도 분석
로컬 사전 검사 + AI 기반 본문 분석
결과 정규화 및 표시

모델 테스트 및 보안 설계

모델별 정확도·응답속도 비교
BYOK 방식 API 키 관리
브라우저 로컬 저장소 활용



프로젝트 개요

해당 이메일은 스포츠 뉴스 관련 내용으로, 위험하거나 의심스러운 요소는 발견되지 않았습니다. 정상적인 뉴스레터 형식의 이메일로 보입니다.

위험도
✔ 낮음

신뢰도
90%



Gmail 메일 분석 및 위험도 분류

- Gmail에서 제목·발신자·주소·본문을 자동 추출해 분석
- 사용자가 메일을 열면 확장 프로그램이 즉시 감지
- 메타데이터·콘텐츠로 피싱 가능성 평가
- 별도 서버 없이 브라우저 내 분석 수행

AI 기반 HIGH/MEDIUM/LOW 판정

- AI 모델을 활용해 피싱 위험도를 세 단계로 분류
- HIGH: 명확한 피싱 신호 감지 시 경고 오버레이 표시
- MEDIUM: 의심스러운 요소 발견 시 주의 필요
- LOW: 정상 메일로 판단되나 체크리스트 제공
- 각 판정에 대한 신뢰도(confidence) 값 함께 제공

브라우저 내 독립 실행 구조

- Chrome MV3 기반으로 설계된 확장 프로그램
- 브라우저에서 독립적으로 동작
- 백엔드 불필요로 개인정보 보호
- API 키·설정은 chrome.storage.local에 안전 저장
- Gmail 흐름을 방해하지 않는 비침투적 설계



문제 정의

왜 피싱 메일 탐지가 필요한가?

- 계정·개인정보 탈취를 위한 대표적 사이버 공격
- 실제 기관 및 기업으로 위장하여 사용자를 속임
- 사용자의 육안 판별만으로는 식별이 어려움
- 자동 탐지 및 경고 시스템 필요



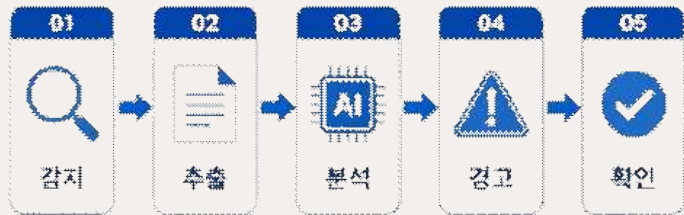
피싱 메일의 주요 위협 요소

- 발신자 주소 위조
- 악성 링크 포함
- 개인정보 입력 유도
- 긴급성 문구를 통한 심리적 압박

Gmail 안에서 바로 분석하는 보안 보조 도구



Gmail 화면에서 메일을 감지하고,
로컬 규칙과 AI 분석을 결합해 피싱 위험을 판단



Gmail 실시간 감지

- 메일 열람 시 자동 감지
- 제목, 발신자, 본문 정보 추출
- 사용 흐름을 방해하지 않음

로컬 규칙 + AI 분석

- 발신자·도메인 1차 검사
- AI가 본문과 메타데이터 분석
- 위험도와 판단 근거 제공

주요 기능



메일 위험도 분석

- Gmail 메일 자동 감지
- 제목·발신자·본문 기반 분석
- HIGH / MEDIUM / LOW 표시
- 고위험 메일 경고 제공



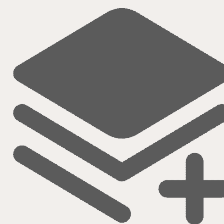
도메인 관리

- 화이트리스트 등록
- 블랙리스트 등록
- 도메인 기반 사전 필터링
- 사용자 맞춤형 관리



분석 로그·통계

- 분석 결과 통계 제공
- API 응답 로그 저장
- 위험도별 메일 분류
- 모델별 분석 결과 추적



다중 모델 지원

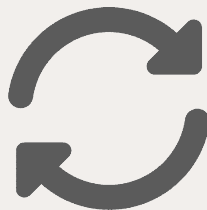
- Groq(LLaMA 3.3 70B),
- Gemini(Gemini 3.1 Flash Lite),
- GPT(GPT-5.5),
- Ollama(Qwen3.5:9b) ,
- 모델별 API 키 관리

AI 분석 방식



1단계: 로컬 사전 검사

- 발신자·도메인 확인
- 화이트리스트 / 블랙리스트 검사
- 제목·메타데이터 의심 신호 탐지
- 빠른 1차 필터링



2단계: AI 기반 본문 분석

- 메일 본문과 메타데이터 전달
- 개인정보 요구·긴급 표현 분석
- 의심 링크와 발신자 위장 확인
- 위험도·신뢰도·요약 반환



3단계: 결과 정규화 및 표시

- HIGH / MEDIUM / LOW로 분류
- confidence 0~100 정리
- 위험 근거와 체크리스트 제공
- 고위험 메일 경고 표시

AI 분석 방식



PhishGuard AI

Gmail 스파이핑 방지

Active

현황

설정

다크 모드

AI 모델 선택

Groq (LLaMA 3.3)

API 키

API 테스트

.....

✓ 키 지정됨 · 분석 활성화

저장

초기화

도메인 목록

화이트리스트와 블랙리스트는 별도 관리 창에서 추가, 검색, 삭제할 수 있습니다.

도메인 목록 관리

추가 검사가 필요합니다

이 이메일에서 일부 의심 요소가 발견되었습니다.

판단 근거

제목에서 'payment to Anthropic, PBC was unsuccessful again'이라는 문구와 발신자 이메일 'failed-payments@mail.anthropic.com'이 실제 Anthropic, PBC의 도메인인지 확인이 필요하며, 로컬 신호는 없지만 발신자명과 이메일이 일치하는지 확인이 필요합니다.

- 1. 제목에서 확인된 'unsuccessful payment' 문구: Anthropic, PBC의 실제 결제 실패 알림인지 확인이 필요합니다.
- 2. 발신자 이메일 'failed-payments@mail.anthropic.com': 실제 Anthropic, PBC의 도메인인지 확인이 필요합니다.

개인정보보호를 위해 본문은 아직 AI에 전송되지 않았습니다.

본문 포함 정밀 분석

나중에 하기

PhishGuard AI

위험도

신뢰도

낮음

80%

해당 이메일은 Anthropic, PBC에서 발송한 것으로, 결제 실패에 대한 안내 메일입니다. 발신자와 도메인이 일치하며, 본문 내용도 결제 정보 갱신을 요청하는 내용으로 보아 정상적인 안내 메일로 판단됩니다.

발신자

failed-payments@mail.anthropic.com

판단 체크리스트

☐ 1. 발신자/도메인 검증: 발신자명과 이메일 주소가 일치하며, 도메인이 공식 도메인으로 확인됩니다.

☐ 2. 링크/도메인 검증: 본문에 포함된 링크는 결제 정보 갱신을 위한 링크로, 공식 도메인으로 확인됩니다.

☐ 3. 개인정보/인증 요구: 본문에서 개인정보나 인증을 요구하는 내용은 없습니다.

☐ 4. 긴급성/압박 표현: 본문에서 긴급성이나 압박을 유도하는 표현은 없습니다.



PhishGuard API 응답 로그

API 키와 메일 본문은 저장하지 않습니다.

새로고침

로그 비우기

닫기

오류, HTTP 상태, 모델, 위험도 검색

전체 상태전체 검사

전체 로그

9

성공

9

실패

0

최근 HTTP

200

실패 원인이 'HTTP 429'면 요청 제한, '5xx'면 서버 오류 가능성이 큼니다. JSON 파싱 실패는 모델 응답 형식이 깨진 경우입니다.

정밀검사 · Groq성공HTTP 200낮음 80%

2026. 06. 14. 오후 09:51:451827msmodel: groq

{

"riskLevel": "LOW",

"confidence": 80,

"summary": "해당 이메일은 Anthropic, PBC에서 발송한 것으로, 결제 실패에 대한 안내 메일입니다. 발신자와 도메인이 일치하며, 본문 내용도 결제 정보 갱신을 요청하는 내용으로 보아 정상적인 안내 메일로 판단됩니다.",

"indicators": [],

"checklist": [

{

"text": "1. 발신자/도메인 검증: 발신자명과 이메일 주소가 일치하며, 도메인이 공식 도메인으로 확인됩니다.",

"flagged": false,

"reason": "발신자명과 이메일 주소가 일치하며, 도메인이 공식 도메인으로 확인됩니다."

},

{

},

{

전체보기복사

간이검사 · Groq성공HTTP 200보통 60%

2026. 06. 14. 오후 09:50:59728msmodel: groq

{

"riskLevel": "MEDIUM",

"confidence": 60,

"needsAdditionalCheck": true,

"reason": "제목에서 'payment to Anthropic, PBC was unsuccessful again'이라는 문구와 발신자 이메일 'failed-payments@mail.anthropic.com'이 실제 Anthropic, PBC의 도메인인지 확인이 필요하며, 로컬 신호는 없지만 발신자명과 이메일이 일치하는지 확인이 필요합니다.",

"signals": [

"1. 제목에서 확인된 'unsuccessful payment' 문구: Anthropic, PBC의 실제 결제 실패 알림인지 확인이 필요합니다.",

"2. 발신자 이메일 'failed-payments@mail.anthropic.com': 실제 Anthropic, PBC의 도메인인지 확인이 필요합니다."

},

{

복사

도메인 목록 관리

허용하거나 차단할 이메일 주소와 도메인을 정리합니다.

새로고침

JSON 내보내기

JSON 가져오기

닫기

example.com 또는 user@example.com

화이트리스트

추가

화이트리스트

0

블랙리스트

0

검색

목록에서 찾기

도메인은 하위 도메인까지 함께 적용됩니다. 예를 들어 `example.com`은 `mail.example.com`에도 적용됩니다.

화이트리스트비우기

블랙리스트비우기

아직 등록된 항목이 없습니다.



개인정보 및 보안 설계

01

별도 백엔드 서버 미사용

사용자의 메일 데이터가 외부 서버로 전송되지 않으며, 모든 처리는 브라우저 내에서 이루어진다.

02

BYOK 방식 API 키 관리

사용자가 직접 API 키를 입력하는 BYOK(Bring Your Own Key) 방식으로 키 관리 책임을 사용자에게 부여한다.

03

브라우저 로컬 저장소 활용

API 키, 설정, 분석 로그는 `chrome.storage.local`에 저장되어 사용자 기기 내에서만 관리된다.

04

메일 본문 분석 최소화

메일 본문 분석은 필요한 경우에만 수행하며, 최소한의 데이터만 AI API로 전송한다.

05

화이트리스트/블랙리스트 로컬 관리

신뢰 도메인과 차단 도메인 목록은 사용자의 브라우저 로컬 저장소에서 관리되어 외부 유출을 방지한다.



모델 테스트 및 평가 도구

AI 모델을 단순 적용한 것이 아니라, 별도의 평가 도구를 통해 모델별 탐지 결과를 비교하고 프롬프트를 개선

평가 도구	평가 방식	지원 모델	확인 지표
- GUI 기반 테스트 프로그램 - Node.js 자동 평가 스크립트 - background.js 프롬프트 직접 로드 - 결과를 JSONL / Summary로 저장	- Hugging Face 피싱 데이터셋 사용 - 정상 / 피싱 샘플 균형 선택 - 모델별 위험도 예측 수행 - LOW / MEDIUM / HIGH 결과 기록 - MEDIUM은 피싱으로 분류	- Groq: LLaMA 3.3 70B - Gemini: Gemini 3.1 Flash Lite - GPT: GPT-5.5 - Ollama: Qwen3.5:9b	- Accuracy - 정상 메일 오탐 수 - 피싱 메일 미탐 수 - 위험도 분포 - 샘플별 판단 요약

데이터셋 일괄 검사

background.js 프로그램을 일괄 검증합니다.

인공지능 모델 (AI Model)

Groq Llama 3.3 70B

API Key 입력

입력한 키는 실행 시 바로 적용됩니다.

Gemini

Groq

GPT

.env에 저장

API 콘솔

평가 데이터셋 (Dataset)

texts.json (이메일 텍스트)

로컬 데이터셋 JSON

선택하면 원격 다운로드 대신 이 파일을 사용합니다.

대기 중

정확도: -

진행: 0 / 0

0%

낮음(LOW) 0 보통(MEDIUM) 0 높음(HIGH) 0



평가를 시작하면 분석 레코드가 카드로 쌓입니다.

결과 리스트에서 레코드를 선택하면 보안 방지 상세 사유 및 프로그램 요약본을 확인할 수 있습니다.

[시스템 상태] PhishGuard Python GUI 로드 완료.

- Gemini Key: 감지됨 (OK)

- Groq Key: 감지됨 (OK)

- GPT Key: 없음 (Warning)

저장된 평가 결과

Ollama

누적 정확도: 67.16%

완료 3회 | 정답 135/201 | 총 201건 | LOW 139 MEDIUM 0 HIGH 62 | FP 14 FN 0

OK	05-26 23:23:03	[ollama]	texts-ollama-2026-05-26T13-55-38-404;
OK	05-26 22:55:03	[ollama]	texts-ollama-2026-05-26T13-45-28-728;
OK	05-26 22:44:05	[ollama]	texts-ollama-2026-05-26T13-43-52-746;

새로고침

파일: phishing-prompt-texts-ollama-2026-05-26T13-55-38-404Z.jsonl
저장 시각: 2026-05-26 23:23:03
JSONL: C:\Users\user\Desktop\phishing\phishguard\tools\..\eval-results\phishing-prompt-texts-ollama-2026-05-26T13-55-38-404Z.jsonl
모델: ollama
데이터셋: texts
정확도: 66.00%
정답: 99 / 150
전체: 150

```
[1] row=14599 expected=phishing predicted=HIGH correct=True
confidence=95 model=ollama
summary=이메일은 정상적인 비즈니스 메일처럼 작성되어 있으나, 발신자 도메인과 링크가 의심스러운 패턴을 보이고 있습니다. 본문에 포함된 링크를 클릭하거나 첨부파일을 열지 마시고, 발신자 정보를 반드시 확인하시기 바랍니다.
indicators=1. 발신자 도메인: sample-14599@dataset.local, 2. 의심스러운 링크: http : / / mail - svcs . com, 3. 의심스러운 발신자 이름: Hugging Face phishing-dataset

[2] row=942 expected=benign predicted=LOW correct=True
confidence=95 model=ollama
summary=이메일은 2000 년 엔론(Enron) 내부 업무 메일의 원본 데이터를 기반으로 생성된 것으로, 현재 시점의 피싱 공격과 무관합니다. 발신자 도메인 및 메일 헤더가 정상적인 내부 시스템 로그와 일치하며, 외부 링크나 악성 첨부파일이 포함되어 있지 않습니다.
indicators=

[3] row=12152 expected=phishing predicted=LOW correct=False
confidence=85 model=ollama
summary=이메일은 케이블 TV 무료 콘텐츠 무료 시청을 약속하는 전형적인 스팸 광고로 보입니다. 발신자 정보나 링크가 정상적인 기업 메일과 다르지만, 악성코드나 개인정보 도용을 목적으로 한 피싱 메일은 아니므로 위험 수준은 낮습니다.
indicators=

[4] row=3641 expected=benign predicted=LOW correct=True
confidence=95 model=ollama
summary=이메일은 1998 년에 개최된 COLING-ACL 워크숍의 공식 발표 내용으로 보이며, 현재 시점에서는 과거의 정상적인 학술 행사 관련 메일입니다. 발신자 도메인이나 링크, 개인정보 요구 사항 등 현대적인 피싱 메일의 전형적인 위험 징후는 전혀 발견되지 않았습니다.
indicators=

[5] row=17194 expected=benign predicted=HIGH correct=False
confidence=95 model=ollama
summary=이메일은 발신자 도메인에 'dataset.local'이라는 가상의 테스트 도메인이며, 발신자 이름에 'phishing'이라는 단어가 포함되어 있어 명백한 피싱 시뮬레이션임을 확인했습니다. 실제 업무와 무관한 제목과 본문 내용으로 인해 정상적인 비즈니스 메일일 가능성이 매우 낮으므로 주의가 필요합니다.
indicators=

[6] row=3661 expected=phishing predicted=HIGH correct=True
confidence=95 model=ollama
summary=이메일은 명백한 피싱 및 사기 메일입니다. 제목과 본문에 '무료 여행'이라는 유혹적인 문구와 함께 불법 도박 사이트인 'kingscasino.com'으로의 링크가 포함되어 있으며, 발신자 도메인도 비정상적입니다.
indicators=1. 발신자 도메인: dataset.local, 2. 의심스러운 링크: http://www.kingscasino.com, 3. 사기성 문구: win a free trip to antigua

[7] row=11294 expected=phishing predicted=HIGH correct=True
confidence=95 model=ollama
summary=이메일은 명백한 피싱 시도입니다. 발신자가 정당한 금융 기관이 아니며, 긴급하게 링크를 클릭하여 정보를 입력하도록 유도하는 전형적인 사기 패턴을 보입니다.
indicators=1. 발신자 도메인: sample-11294@dataset.local, 2. 발신자 이름: Hugging Face phishing-dataset, 3. 위험 문구: fraudulent activity has been registered on your account, 4. 위험 문구: click here to prove your identity
```

내부 테스트 결과(각 200 회)



Groq(LLaMA 3.3 70B)

Ollama(Qwen3.5 9B)

95.35%

67.16%



한계 및 향후 개선 방향

현재는 실사용 가능한 프로토타입 단계이며, 정확도와 적용 범위를 높이기 위한 개선이 필요

현재 한계

- Gmail DOM 변경에 영향 가능
- AI API 상태에 따라 속도 변동
- 모델별 결과 품질 차이
- 실시간 분석 시 응답 지연 가능

탐지 기능 개선

- URL 샌드박스 추가
- 첨부파일 위험도 분석
- 링크 실제 접속 분석 강화
- DOM 변경 자동 대응

사용성 확장

- 조직용 정책 관리
- 사용자 신고 기반 피드백
- 다국어 메일 지원
- 모델별 설정 고도화

평가 강화

- 대규모 피싱 데이터셋 평가
- 실제 사용자 환경 테스트
- 오탐 / 미탐 분석
- 모델별 성능 비교 체계화